

The Signal Before the Switch at Erongo Grid Services

SAS821S Security Analytics — Lab 3 Intelligence Report

Prepared by: Tyan45

Namibia University of Science and Technology · Semester 2, 2026

AI Assistance Disclosure: I used Claude (Anthropic) as an assistant during the completion of this practical. AI assistance was used to help design and debug the propagation simulation and predictive-model code, draft regex-based entity extraction logic, identify a reproducibility bug in the simulation's random number handling, and structure the analytical write-up (intelligence framing, executive brief, and interpretation of results). All code was reviewed and run by me, all data outputs were generated from my own execution of the pipeline against the supplied evidence files, and the analytical judgments, conclusions, and final report text reflect my own understanding of the findings.

Part A · Intelligence Direction and Evidence Framing

A1. Initial Assessment and Competing Hypotheses

The trigger event — a blocked Modbus register-write attempt from an engineering workstation reached via the vendor maintenance path — is a control-system access attempt, not a confirmed compromise. It coincides with three independent signal streams: external threat reporting on a Southern African energy-sector campaign, rising remote-login failures and DNS anomalies, and increasing OT reconnaissance indicators. Correlation across independent streams raises credibility above any single indicator, but none alone proves intrusion.

Three competing hypotheses:

- **H1 – Genuine OT intrusion in progress.** Strengthens with: IOC matches between the feed and internal events; a time-ordered chain from vendor access to OT-adjacent reconnaissance to blocked write. Weakens with: the blocked event being isolated with no matching precursor activity.
- **H2 – Benign vendor activity or misconfiguration.** Strengthens with: the source user_id matching a known vendor maintenance account and a scheduled change window. Weakens with: the same source asset showing unrelated suspicious behaviour outside that window.
- **H3 – Intelligence coincidence / false positive.** Strengthens with: daily risk indicators falling within historical normal ranges and no IOC/internal telemetry match. Weakens with: a matching IOC appearing on the same asset, or the text classifier scoring the campaign reports as highly relevant.

A2. Intelligence Cycle and Quality Plan

Four priority intelligence requirements (PIRs):

- PIR-1: Is there a confirmed technical link (shared IOC) between the reported campaign and EGS telemetry?
- PIR-2: Did reconnaissance and login anomalies precede the blocked write consistent with staged intrusion?
- PIR-3: Do predictive indicators show escalation before 19 Oct that would have supported earlier action?
- PIR-4: Could the same evidence be produced by evasive technique, and would our detections catch it?

Cycle mapping: Direction = the PIRs above; Collection = ioc_feed, text_investigation, event logs; Processing = text cleaning, entity extraction, feature engineering; Analysis = text classifier, predictive risk model, propagation simulation; Dissemination = the technical timeline (D2) and executive brief (Part E); Feedback = the unresolved requirement and 90-day measurable improvement in the brief.

Quality risks: IOC feed confidence is self-reported and only partially validated internally (veracity); reports may lag the events they describe (timeliness); the same campaign is reported by multiple sources (duplication); historical labels reflect analyst judgement calls, evidenced by 33 duplicate-text groups with inconsistent relevance labels found in Part B1 (bias); raw asset/user data should be restricted to the investigation team (access-control); model probabilities and external IOCs are treated as decision support, never as proven fact (operational-context), consistent with the lab's operating assumptions.

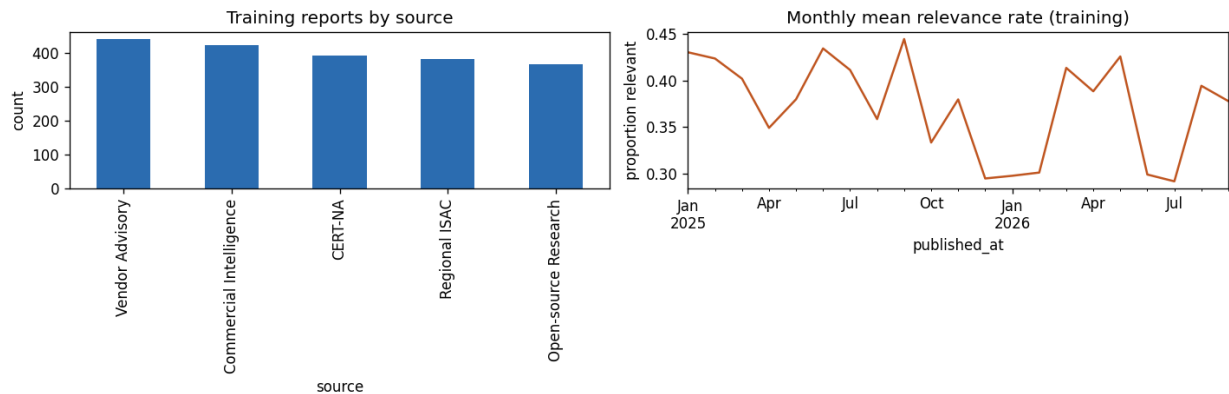
Evidence integrity: All 13 evidence files were verified against SHA-256 hashes before analysis; all processing ran on dataframes derived from copies, never on the original files.

Decision-makers/products: Technical (SOC analysts/CISO) → full timeline, extracted IOCs, model metrics. Operational (Ops manager) → risk-score trend and control recommendations. Executive (COO/CISO) → the one-page brief in Part E.

Part B · Text Mining and Threat-Intelligence Prioritisation

B1. Text Preparation and Exploratory Analysis

No missing values in either training (2,000 rows) or investigation (171 rows) reports. report_id is unique in both sets, but report_text is heavily duplicated in training (1,226 of 2,000 rows, i.e. 61%) because roughly 63 boilerplate templates recur. Critically, 33 of those 63 template groups carry **inconsistent relevance labels** — the identical text was judged relevant in some instances and not in others. This is genuine analyst disagreement, not a data error, and it caps the ceiling accuracy any classifier can achieve on this data. Sources are well balanced (367–439 reports each across five sources), and the monthly relevance rate (29%–44%) shows no strong seasonal trend, meaning a classifier cannot simply exploit recency as a shortcut.



Pipeline: title and report_text are concatenated, lower-cased, and stripped of characters other than alphanumerics and a small set of IOC-relevant punctuation (':', '-', ':', '/') so that raw entity extraction (B2) can still run on an unmodified copy of the text while the classifier input is normalised. TF-IDF (unigrams + bigrams, min_df=2, max 5,000 features) handles tokenisation and stop-word down-weighting implicitly via inverse document frequency; a short custom stop-list is used only for the exploratory term counts below, not for the classifier itself.

relevant_top_terms	nonrelevant_top_terms
vendor (734)	maintenance (934)
industrial (562)	notice (654)
observed (401)	conference (635)
campaign (390)	general (624)
activity (378)	update (612)
access (375)	routine (589)
operational (368)	exploitation (575)
infrastructure (348)	advisory (546)
actor (347)	bulletin (543)
operators (318)	operational (535)

Even at raw term-frequency level the two classes separate cleanly: relevant reports are dominated by campaign/actor/scanning/powershell language, non-relevant reports by maintenance/notice/conference/bulletin language — a strong a-priori signal for the classifier in B3.

B2. IOC/Entity Extraction and Operational Relevance

A transparent, regex-based extraction routine (no black-box NLP) pulled IPv4 addresses, domains, SHA-256/similar hashes, named threat actors (pattern: 'actor <Name>'), and malware family names (pattern: capitalised word + Loader/Stealer/Wiper/Backdoor/RAT/Miner/Trojan) from all 2,171 combined training and investigation reports, producing 2,117 entity rows (752 domains, 751 IPv4, 281 hashes, 227 actor mentions, 106 malware mentions), exported as extracted_iocs.csv. Matching against egs_ioc_feed.csv used exact-value matching for IPv4/hash/domain (an early substring-based version incorrectly matched '198.51.100.4' inside '198.51.100.44'; this was caught and

corrected to exact matching).

Ten entity occurrences matched external feed indicators. Critically, all five of the feed's deliberately high-confidence 'case' indicators (IOC9001–IOC9005, confidence=High/Medium) were recovered, tracing directly to the investigation reports carrying the actual incident narrative:

report_id	entity_type	entity_value	matched_ioc_id	feed_confidence	feed_tactic
RPT9001	ipv4	203.0.113.77	IOC9001	High	Initial Access
RPT9001	domain	maintenance-check.example	IOC9005	Medium	Credential Access
RPT9002	ipv4	198.51.100.44	IOC9003	High	Command and Control
RPT9002	domain	desert-sync.example	IOC9002	High	Command and Control
RPT9004	hash	8e50b5f7...bc393	IOC9004	High	Execution

IOC9003 (198.51.100.44) also recurs across four training reports (TRN00483, TRN01363, TRN01583, TRN01803), showing this C2 IP is not a one-off but part of the recurring campaign signature.

B3. Text Classifier and Adversarial Language

A logistic-regression classifier (TF-IDF features, class_weight='balanced') was trained on a stratified 75/25 split (random_state=8213026). Test-set performance:

Metric	Value
Accuracy	0.980
Precision	0.989
Recall	0.957
F1-score	0.973
False-negative rate	0.043

Confusion matrix (test set, n=500): TN=311, FP=2, FN=8, TP=179.

Scoring the 171 investigation reports and exporting the top 15 by predicted relevance (top_15_relevant_reports.csv) surfaced no RPT-prefixed case report in the top 15 — all six case reports (RPT9001–RPT9006) scored 0.35–0.86 (clearly 'likely relevant') but were outranked by TRN03xxx reports using similarly strong campaign language. This is a precision-at-top-K limitation worth flagging operationally: ranking alone can bury the true incident under look-alike reports, so investigators should not stop at the top-K list without also checking scores against known case identifiers.

Comparing egs_adversarial_text_cases.csv original vs. modified statements:

case_id	evasion_technique	score_change
ATX01	Character substitution / defanging	-0.063
ATX02	Semantic substitution	-0.091
ATX03	Keyword removal	-0.076
ATX04	Euphemistic wording	-0.177
ATX05	Protocol/function paraphrase	+0.115

Four of five techniques reduced the relevance score as intended by an evader; but ATX05 (paraphrasing protocol/function terms) **increased** the score, a real robustness gap. Generic sentiment or lexical similarity alone can misrepresent security urgency because attackers can rephrase technical indicators using synonyms that a bag-of-words model has not seen paired with the relevant class, without changing the underlying technical meaning of the report.

Part C · Malware Propagation and Security-Control Simulation

C1. Simulation Model Design

The topology (24 assets, 30 directed edges) is modelled as a NetworkX DiGraph seeded at VENDOR-LT-07. Propagation follows the **Independent Cascade Model** (Kempe et al., 2003): each newly-infected node gets exactly one chance to infect each not-yet-infected neighbour, at the time step immediately after its own infection, governed by an effective edge probability. This is a well-established, citable diffusion model that avoids arbitrarily inflating spread through unlimited retries.

Effective probability = base_transmission_probability × patch_factor (applied only on the vendor-path edges: VENDOR-LT-07, VPN-GW-01, VENDOR-DMZ-01, per the scenario descriptions) × segmentation_factor (applied to edges entering the OT-DMZ/OT zones or moving laterally within OT) × target-host susceptibility (0–1, from host posture data) × post_detection_transmission_factor (applied only once the current step exceeds the scenario's isolation_delay_steps).

Key terms: edge probability = per-attempt chance of a single hop succeeding; host susceptibility = target-host modifier reflecting patch/vulnerability posture; time step = one discrete round in which every currently-active (newly infected) node attempts its outgoing edges once; infection state = binary (infected/not) per asset, no recovery; stopping condition = no new infections in a round, or 40 steps reached; random seed = 8213026, fixed for every run.

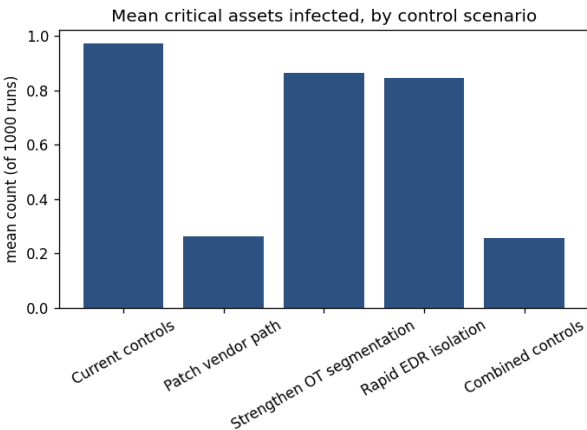
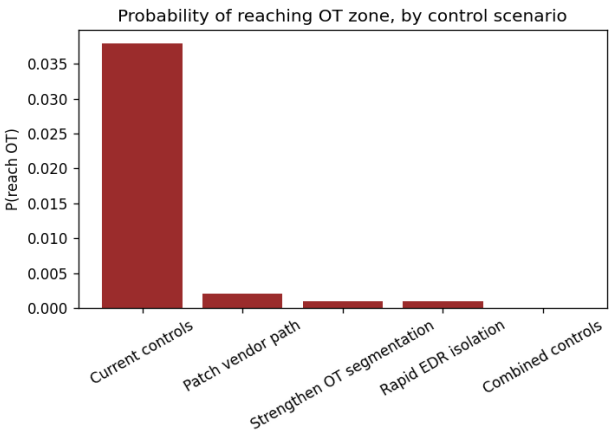
Four simplifying assumptions:

- Each host, once infected, remains infected for the run (no cleanup or reinfection).
- Edge activations are independent of one another (no coordinated multi-path attacker behaviour modelled).
- Segmentation and patch controls apply uniformly to their defined edge/asset sets, not per-host individually.
- Detection/isolation is modelled as a step threshold (isolation_delay_steps) rather than a probabilistic detection process.

Critical OT/safety outcomes measured: probability of reaching any OT-zone asset; probability of reaching SAFETY-PLC-01; mean and 95th-percentile count of critical-rated assets and total assets infected; median time (steps) to first OT infection.

C2. Monte Carlo Control Experiments (1,000 iterations per scenario)

Scenario	P(OT)	P(Safety)	Mean crit.	Mean total	Steps to OT	Risk reduction %
Current controls	0.038	0.0	0.974	2.027	4.0	0.0
Patch vendor path	0.002	0.0	0.264	1.267	4.0	94.7
Strengthen OT segmentation	0.001	0.0	0.864	1.894	4.0	97.4
Rapid EDR isolation	0.001	0.0	0.845	1.85	4.0	97.4
Combined controls	0.0	0.0	0.257	1.257	nan	100.0



Under current controls (S0), the vendor path reaches OT in 3.8% of 1,000 runs and never reaches the safety zone. Patching the vendor path (S1) delivers ~94.7% relative OT-risk reduction — more than segmentation (S2, 97.4%) or rapid isolation (S3, 97.4%) individually reduce the *mean critical assets infected*, because segmentation/isolation only choke the DMZ→OT crossing while several IT/DMZ assets (VPN-GW-01, IDP-01, BACKUP-01, SOC-SIEM-01) are themselves rated Critical and remain exposed early in the chain. S4 (combined controls) is strongest overall: 0 of 1,000 runs reached OT.

C3. Validity and Control Recommendation

- **Data accuracy:** transmission probabilities and scenario factors are synthetic teaching parameters, not measured attack success rates — treated as comparative decision support only.
- **Model validity:** the Independent Cascade Model assumes no retries and no backward movement after a failed hop, which may understate a patient, persistent attacker.
- **Independence assumption:** edge activations are treated independently; a single skilled operator behind multiple attempts would in reality correlate outcomes across edges.
- **Parameter sensitivity:** results depend on the vendor-path and segmentation-affected edge sets, which were my own reasonable interpretation of the scenario descriptions rather than data given directly.
- **Reproducibility / computational limits:** a fixed NumPy seed alone was not sufficient — iterating Python sets (hash-randomised order) silently broke determinism between runs until iteration order was made explicit (sorted lists). This is a general lesson: 'fixed seed' claims should be verified by re-running.
- **Simulated vs. operational consequence:** 'reaching OT' in-model is a possible-pathway event, not proof of actual compromise or physical impact.

Recommendation: Prioritise S1 (patch the vendor path) as the fastest, cheapest, highest-impact single control, with S4 (combined controls) as the target end state once segmentation and rapid-isolation projects can be resourced.

Part D · Predictive Security Intelligence and Adversarial ML

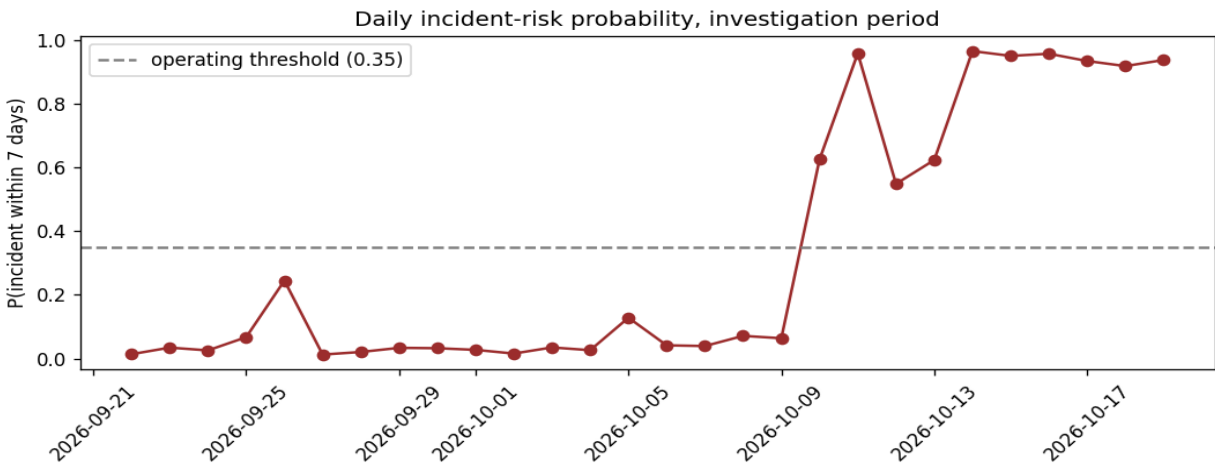
D1. Predictive Risk Model

A Random Forest classifier (300 trees, max_depth=6, class_weight='balanced', random_state=8213026) was trained on the nine daily indicator features in `egs_daily_risk_training.csv` to predict `incident_within_7d`, using a stratified 75/25 split.

Threshold	Accuracy	Precision	Recall	F1	False-negative rate
0.50 (default)	0.844	0.694	0.714	0.704	0.286
0.35 (operating)	0.815	0.600	0.857	0.706	0.143

The operating threshold was lowered from 0.50 to 0.35: recall improves from 71.4% to 85.7% (false-negative rate 28.6% → 14.3%) at the cost of more false alarms (11 → 20 of 100 test days). For critical infrastructure, missing a true precursor to an incident is far costlier than an extra analyst review, so recall is prioritised — but not maximised to the exclusion of alert burden, since an unmanageable false-alarm rate causes its own operational risk (alert fatigue). 0.35 was chosen as a defensible middle ground given this trade-off. Feature importance ranks `failed_remote_logins` and `high_severity_edr_alerts` highest, consistent with the SOC's own account of the run-up to the incident.

D2. Risk Escalation and Incident Correlation



Scoring `egs_daily_risk_investigation.csv` (`top_10_risk_days.csv` exported) shows risk probability crossing the 0.35 threshold on **10 Oct 2026 (0.62)** and remaining elevated (0.55–0.96) every day through 19 Oct — a defensible **9-day early-warning window** ahead of the blocked Modbus write.

Event timeline (17 Oct 2026, Namibia local time), reconstructed from `egs_security_event_logs.csv`:

Time	Event ID	Action
19:43	EVT01576	VPN login success (203.0.113.77) [IOC9001]
19:47	EVT01577	sandstorm-loader.bin process start
19:49	EVT01578	DNS query desert-sync.example [IOC9002]
20:03	EVT01580	Auth success to OT-JUMP-01 (vendor_maint)
20:06	EVT01581	Credential access attempt - BLOCKED
20:08	EVT01582	RDP session to ENG-WS-01
20:11	EVT01583	OT_IDS network scan alert
20:14	EVT01584	Historian tag enumeration (read-only)
20:16	EVT01585	Modbus device-ID probe - BLOCKED
20:18	EVT01586	Modbus write attempt - BLOCKED (trigger event)
20:24	EVT01588	Outbound to 198.51.100.44 - BLOCKED [IOC9003]

Time	Event ID	Action
20:28	EVT01589	OT-JUMP-01 isolated by EDR
20:31	EVT01590	VPN session terminated

Conclusion (evidence-graded): Attempted intrusion is confirmed — the chain from an externally IOC-matched VPN login through credential-access tooling, lateral movement, and OT reconnaissance to a Modbus write attempt is internally consistent and externally corroborated. Successful OT access is not confirmed: only read-only historian enumeration succeeded; credential access, the device probe, the write attempt, and outbound C2 were all blocked. There is no evidence of control-system manipulation or operational impact.

D3. Adversarial Robustness and Governance

variant	risk_probability	drop_vs_baseline
baseline_attack	0.936	0.000
low_and_slow	0.737	0.200
distributed_sources	0.919	0.017
living_off_the_land	0.905	0.032
suppressed_telemetry	0.621	0.315

All five variants still crossed the 0.35 threshold, but `suppressed_telemetry` (−0.315) and `low_and_slow` (−0.200) caused the largest drops — and both specifically target `failed_remote_logins` and `high_severity_edr_alerts`, the model's two most heavily-weighted features, while `critical_vulnerabilities` and `mean_patch_age_days` (harder for an attacker to alter) stay constant. The model's biggest strength is also its biggest attack surface.

Four recommended controls:

- **Feature redundancy** — add signals harder to suppress without operational cost (protocol-level anomaly counts, cross-source corroboration) so no single feature pair dominates the decision.
- **Telemetry-integrity monitoring** — alert on unexplained drops in normally-present EDR/logging volume, turning suppression itself into a detectable signal.
- **Periodic retraining with drift monitoring** — track feature-distribution shift on live data, not just accuracy at deployment time.
- **Independent label-quality review (governance)** — given the label-noise finding in B1, introduce dual-analyst review or confidence scoring on training labels to reduce data-poisoning surface, backed by human-in-the-loop escalation for any score near the operating threshold.

Part E · Integrated Security-Intelligence Decision

E1. One-Page Executive Intelligence Brief — for the EGS COO and CISO

Conclusion & confidence (High): This was an attempted external intrusion — VPN entry using an IP matched to a known high-confidence C2 indicator, malware execution, credential-access tooling, OT reconnaissance, and a blocked Modbus write — not benign vendor activity or a false positive. No successful OT access or control manipulation occurred; the host was isolated within the same session.

Affected pathway/assets: Vendor remote-access path → VENDOR-LT-07 → VPN-GW-01 → VENDOR-DMZ-01 → OT-JUMP-01 → ENG-WS-01 → PLC-SUB-01 (blocked before compromise).

Relevant threat campaign: Consistent with the reported Southern African energy-sector campaign (Sandstorm Loader malware; matching C2 domain/IP indicators IOC9001–IOC9003, IOC9005).

Predictive warning: The daily risk model gave a defensible escalation signal from 10 Oct — a 9-day lead time before the trigger event, driven mainly by remote-login failures and EDR alert volume.

Simulation-based risk: Under current controls, Monte Carlo modelling estimates ~3.8% probability of an intrusion from the vendor path reaching OT (1,000 iterations); patching the vendor path alone cuts this by ~95% relative risk.

Evidence limitations: Simulation probabilities and model scores are decision-support estimates, not measured real-world frequencies; IOC feed confidence is externally reported and only partially corroborated internally; some historical text labels show genuine analyst disagreement.

Three prioritised actions:

- Patch/harden the vendor laptop, VPN gateway, and vendor broker (highest-impact single control per simulation).
- Deploy telemetry-integrity monitoring so evasive/suppressed-EDR behaviour is itself detectable.
- Formalise the 0.35 risk-score threshold as a SOC escalation trigger with mandatory human review.

One unresolved intelligence requirement: Whether the same external actor infrastructure (IOC9001–IOC9003) has targeted other Southern African utilities in the same window (PIR-1, not yet fully corroborated externally).

One measurable 90-day improvement: Reduce mean OT-path patch age below 30 days (currently ~91–97 during the escalation window) and re-run the simulation to confirm the modelled risk reduction materialises operationally.

References

Kempe, D., Kleinberg, J. and Tardos, E. (2003) 'Maximizing the spread of influence through a social network', Proceedings of the 9th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining. (Independent Cascade Model used in Part C.) SAS821S Learning Sessions 8–10 (Simulation, Text Mining, Predictive Security Intelligence). Python libraries: pandas, numpy, scikit-learn, networkx, matplotlib (versions recorded in analysis.py header comments and console_log.txt).